Lập trình mạng · Chương 5

Bảo mật: TLS và secure socket trong Java

TS. Đặng Ngọc Hùng

Chương 5: Các chủ đề nâng cao

1 Bảo mật

- TLS và secure socket trong Java
- Xác thực và phân quyền với OAuth 2.0 và JWT

2 Hiệu năng

- Lời gọi không chặn với CompletableFuture và gRPC async stub
- NIO, Selector và mẫu Reactor

3 Độ tin cậy

- Retry, request ID và checksum trên UDP
- Backoff, circuit breaker và health check

4 IoT

- Bài toán ứng dụng: giám sát cảm biến với MQTT và CoAP

Dữ liệu dạng rõ, server không được xác thực

1. Dịch vụ tra cứu gửi dữ liệu **dạng rõ**: máy nào trên đường truyền cũng đọc và sửa được
2. Client không biết mình có đang kết nối tới **đúng server** hay không
3. **TLS**: mã hóa đường truyền và xác thực server bằng **chứng chỉ**

> **Câu hỏi của phần:** TLS bảo vệ kết nối thế nào, và bật TLS cho dịch vụ tra cứu bằng Java ra sao?

Trên đường truyền, dữ liệu tra cứu hiện nguyên văn

Java

```
Socket server = new Socket("127.0.0.1", 9199);
System.out.println(direction + " " + n + " bytes: " + show(buf, n));
out.write(buf, 0, n);  // chuyển tiếp nguyên vẹn
```

Kết quả chạy

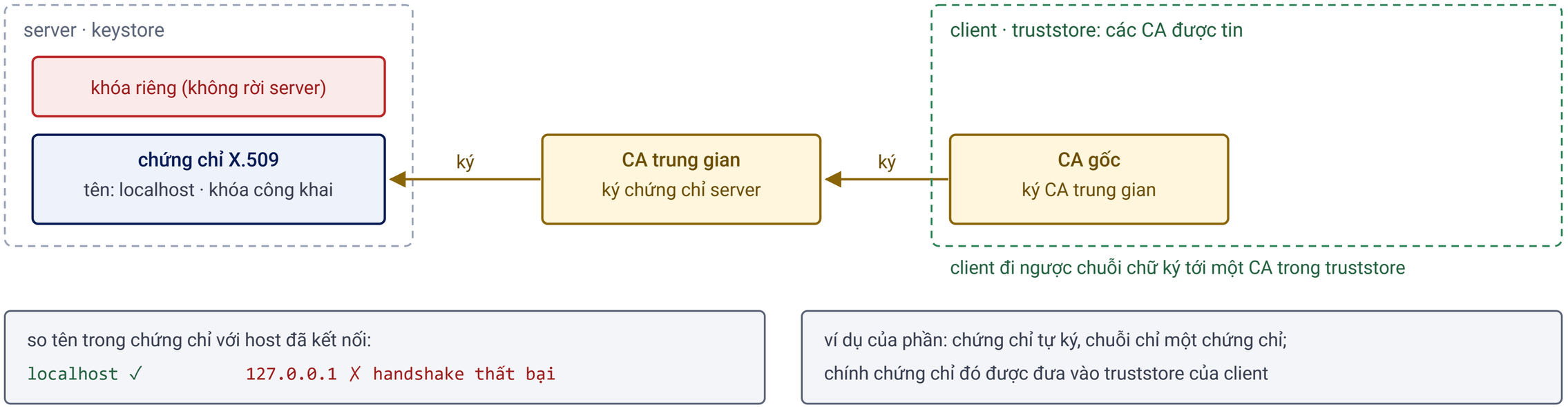
```
tap on port 9200 -> 127.0.0.1:9199
client -> server 7 bytes: "hanoi\n"
server -> client 32 bytes: "OK Thủ đô của Việt Nam\n"
```

Handshake TLS: thỏa thuận khóa, xác thực server, rồi mã hóa



Handshake TLS: trao đổi phần khóa để có khóa phiên, server chứng minh danh tính bằng chứng chỉ; sau đó mọi dữ liệu được mã hóa.

Chứng chỉ, keystore, truststore và kiểm tra hostname



so tên trong chứng chỉ với host đã kết nối:

`localhost ✓` `127.0.0.1 ✗ handshake thất bại`

ví dụ của phần: chứng chỉ tự ký, chuỗi chỉ một chứng chỉ;
chính chứng chỉ đó được đưa vào truststore của client

Keystore (server): khóa riêng và chứng chỉ. **Truststore** (client): các CA được tin. Client kiểm tra chuỗi tin cậy rồi **kiểm tra hostname**.

Tạo keystore và truststore bằng keytool

Bash

```
keytool -genkeypair -alias lookup -keyalg EC -validity 365 \
    -dname "CN=localhost" -ext "SAN=dns:localhost" \
    -keystore server.p12 -storepass changeit
keytool -exportcert -alias lookup -rfc -file server.crt \
    -keystore server.p12 -storepass changeit
keytool -importcert -alias lookup -file server.crt -noprompt \
    -keystore client-trust.p12 -storepass changeit
```

Kết quả chạy

```
$ sh make-certs.sh
Generating 384 bit EC (secp384r1) key pair and self-signed certificate (SHA384withECDSA) with a validity of 365 days
    for: CN=localhost
Certificate stored in file <server.crt>
Certificate was added to keystore
```

Server TLS chỉ đổi cách tạo listening socket; Tap chỉ thấy bản ghi mã hóa

Java

```
System.setProperty("javax.net.ssl.keyStore", "server.p12");  // khóa riêng và chứng chỉ của server
System.setProperty("javax.net.ssl.keyStorePassword", "changeit");
listener = SSLServerSocketFactory.getDefault().createServerSocket(9199);  // listening socket TLS
```

Kết quả chạy

```
tap on port 9200 -> 127.0.0.1:9199
client -> server 410 bytes: 16 03 03 01 95 01 00 01 91 03 03 08 03 69 72 8f ...
server -> client 127 bytes: 16 03 03 00 7a 02 00 00 76 03 03 a7 73 f0 1c 49 ...
client -> server 6 bytes: 14 03 03 00 01 01
server -> client 6 bytes: 14 03 03 00 01 01
server -> client 70 bytes: 17 03 03 00 41 00 71 55 93 56 e4 a1 fb 21 8d e8 ...
server -> client 457 bytes: 17 03 03 01 c4 b1 6f b6 8a 57 11 7e dc 35 42 83 ...
server -> client 149 bytes: 17 03 03 00 90 ab 4e 83 df 44 de 99 31 78 b7 dd ...
server -> client 90 bytes: 17 03 03 00 55 0a 76 52 b2 aa ba b4 fc b1 ff e1 ...
client -> server 90 bytes: 17 03 03 00 55 ba 33 26 b6 65 fe d5 32 8b e7 90 ...
server -> client 711 bytes: 17 03 03 02 c2 85 a2 85 e3 6e 3e e1 10 ff 7b ce ...
client -> server 45 bytes: 17 03 03 00 28 60 65 fb 5d 5e fa 99 69 a7 dc 87 ...
server -> client 70 bytes: 17 03 03 00 41 9c 72 19 23 ff 0e 57 18 d5 41 ee ...
server -> client 40 bytes: 17 03 03 00 23 79 40 ce f0 97 6b 18 1d 05 47 4a ...
server -> client 40 bytes: 17 03 03 00 23 7d 4c 9a 28 98 30 15 8b d0 e6 c7 ...
```

SSLSocket không tự kiểm tra hostname; đừng tắt kiểm tra

Java

```
SSLSocket socket = (SSLSocket) SSLSocketFactory.getDefault().createSocket(host, port);
SSLParameters params = socket.getSSLParameters();
params.setEndpointIdentificationAlgorithm("HTTPS");  // bật kiểm tra hostname theo chứng chỉ
socket.setSSLParameters(params);
```

Kết quả chạy

```
$ LookupClient tls 127.0.0.1 9199 hanoi
SSLHandshakeException: (certificate_unknown) No subject alternative names matching IP address 127.0.0.1 found
$ LookupClient tls-no-hostname-check 127.0.0.1 9199 hanoi
TLSv1.3 TLS_AES_256_GCM_SHA384, server cert CN=localhost
hanoi -> OK Thủ đô của Việt Nam
$ LookupClient tls localhost 9199 hanoi --default-trust
SSLHandshakeException: (certificate_unknown) PKIX path building failed: sun.security.provider.certpath.SunCertPat ...
```

- SSLSocket **không tự kiểm tra hostname**: phải đặt endpoint identification algorithm
- Tắt kiểm tra chứng chỉ hay hostname để chương trình chạy được là **lỗ hổng**

Câu hỏi 1

Trong ví dụ của phần, file client-trust.p12 là truststore. Truststore chứa gì và bên nào dùng?

A. Khóa riêng của server; server dùng để ký trong handshake.

B. Mật khẩu của client; server dùng để xác thực client.

C. Các chứng chỉ được tin (thường là CA); client dùng để kiểm tra chứng chỉ server gửi tới.

D. Khóa phiên đã thỏa thuận; cả hai bên dùng để mã hóa.

Câu hỏi 1

Trong ví dụ của phần, file client-trust.p12 là truststore. Truststore chứa gì và bên nào dùng?

A. Khóa riêng của server; server dùng để ký trong handshake.

B. Mật khẩu của client; server dùng để xác thực client.

C. Các chứng chỉ được tin (thường là CA); client dùng để kiểm tra chứng chỉ server gửi tới.

D. Khóa phiên đã thỏa thuận; cả hai bên dùng để mã hóa.

Truststore chứa các chứng chỉ, tức khóa công khai, mà client tin. Khóa riêng của server nằm trong keystore ở server và không bao giờ được gửi đi; khóa phiên được tính ra trong handshake, không lưu trong file.

Câu hỏi 2

Kẻ tấn công có một chứng chỉ hợp lệ, do CA mà client tin cấp, cho tên miền của chính họ. Nếu client kiểm tra chuỗi tin cậy nhưng không kiểm tra hostname, điều gì xảy ra khi kẻ đó chặn kết nối của client tới lookup.example?

A. Client chấp nhận server giả, vì chứng chỉ của kẻ tấn công cũng có chuỗi tin cậy hợp lệ.

B. Handshake thất bại vì chứng chỉ không hợp lệ.

C. Dữ liệu vẫn an toàn vì đã được mã hóa.

D. Kẻ tấn công không thể chặn một kết nối TLS.

Câu hỏi 2

Kẻ tấn công có một chứng chỉ hợp lệ, do CA mà client tin cấp, cho tên miền của chính họ. Nếu client kiểm tra chuỗi tin cậy nhưng không kiểm tra hostname, điều gì xảy ra khi kẻ đó chặn kết nối của client tới lookup.example?

A. Client chấp nhận server giả, vì chứng chỉ của kẻ tấn công cũng có chuỗi tin cậy hợp lệ.

B. Handshake thất bại vì chứng chỉ không hợp lệ.

C. Dữ liệu vẫn an toàn vì đã được mã hóa.

D. Kẻ tấn công không thể chặn một kết nối TLS.

Chuỗi tin cậy chỉ cho biết chứng chỉ do một CA được tin cấp; kiểm tra hostname mới cho biết chứng chỉ cấp cho đúng server client muốn kết nối. Dữ liệu vẫn được mã hóa, nhưng mã hóa tới chính kẻ tấn công.

Tổng kết

1. **TLS** mã hóa đường truyền; **handshake TLS** thỏa thuận khóa phiên và xác thực server

2. **Chứng chỉ X.509** gắn tên với khóa công khai; server giữ **keystore**, client giữ **truststore**

3. **SSLSocket** cần bật **kiểm tra hostname**; không tắt kiểm tra để chương trình chạy được

Từ khóa cần nhớ TLS · handshake TLS · chứng chỉ X.509 · keystore · truststore · kiểm tra hostname · SSLSocket

Mở rộng

Chủ đề nâng cao

- Mutual TLS: xác thực cả client
- Certificate pinning

Bài tập mở rộng

Tạo CA riêng bằng keytool, ký chứng chỉ cho server, cấu hình client chỉ tin CA đó.

Tiếp theo

Bảo mật: xác thực và phân quyền với OAuth 2.0 và JWT